

PICKUP PROMPT — Git-Vista M1.13b sandbox (#66)

Paste this whole file as the first message of a new Claude Code session in `/home/tom/projects/Git-Vista`. It is written to be self-contained.

Who you are and what you're doing

You are Lane A, the orchestrator, on account **thomas2025** (Max), working in the main checkout `/home/tom/projects/Git-Vista`. The previous session ran ~30 hours and was ended deliberately for context length, not because anything broke.

You are building **M1.13b — the Git-process sandbox**, the largest remaining piece of milestone M1. Issue #66. Branch `feature/m1.13b-sandbox-plan` is already checked out and pushed.

Read these three files before doing anything else: 1. `handoff.md` (repo root, gitignored) — full state 2. `docs/superpowers/plans/2026-07-28-m1.13b-sandbox.md` — the 18-task plan, ~3900 lines 3. `docs/superpowers/specs/2026-07-28-m1.13-round4-verdict.md` — the settled design

The design is SETTLED after four failed rounds. Do not re-litigate it. Only the code and the plan's implementation details are in question.

Where things actually stand

	Status
<code>main</code>	9256ffd, clean, zero open PRs
Branch	<code>feature/m1.13b-sandbox-plan</code> , ~8a2428c (auto-checkpoint 112), pushed
Plan doc	Written, 18 tasks — but has 7 BLOCKING defects, see below
Task 1 (Policy + <code>sandbox_argv</code>)	BUILT, green, committed — <code>crates/git-vista-server/src/sandbox/mod.rs</code> , <code>argv.rs</code>
Task 2 (deps + F10 gate)	BUILT, green, committed — <code>sandbox/deps.rs</code> , <code>docs/NATIVE_DEPENDENCIES.md</code>
<code>./dev</code> gate	All 5 checks green. 653 tests pass, 0 fail
Tasks 3-18	Not started. Task 3 is NOT safe to execute until the plan is fixed

Tasks 1 and 2 already absorbed several review findings (the workflow injected them into the builder's prompt), so the built code is ahead of the plan text in places — e.g. `DEFAULT_SECRET_DENIES` was renamed `DEFAULT_SECRET_EXCLUDES`, `/dev` and `/proc` grants were added via a new `default_system_trees(tier)` helper, and `sandbox_argv` emits `--exclude <path>` rather than any deny rule. **Read the real code before trusting the plan's description of it.**

The critical lesson from this session — internalize it

An adversarial review agent found 7 blocking defects **by compiling C probes and running them against the kernel**, not by reasoning. Two of them invalidated the plan's central mechanism. Rounds 1-3 of this issue all died of reasoning-instead-of-measuring.

When a claim is about kernel behaviour, measure it. Every time.

BLOCKING defects in the plan (must fix before Task 3)

1. **Zero-access Landlock deny rules are rejected by the kernel.** MEASURED: `landlock_add_rule` with `allowed_access = 0` returns -1 / **ENOMSG(42)**. Task 3.4's `add_path_rule(ruleset, p, 0)` makes the shim exit 92 on every launch on any host where `~/.ssh` exists. Nothing sandboxed ever runs.
2. **Nested rules do NOT shrink ancestor grants.** MEASURED: with `$HOME` granted `READ` and `~/.ssh` granted only `MAKE_BLOCK`, reading `~/.ssh/known_hosts` **succeeded** (control: `/etc/hostname` correctly denied, so the ruleset was live). Global Constraint 9's stated premise is false. **D5 Option B — the verdict's "structural answer" to compatibility whack-a-mole — is not implementable as written.** Fix direction: Landlock is deny-by-default, so denial = **not granting**. Enumerate `$HOME`'s entries at policy-build time, add a rule per entry, skip the secret set; recurse one level for `.config/gh`. **This replacement has NOT been measured yet — measure it before writing Task 3.**
3. **`env!("CARGO_BIN_EXE_gv-sandbox")` does not exist in unit tests.** MEASURED: Cargo sets it only for **integration tests and benchmarks**. `git-vista-server` is bin-only, so integration tests can't use the crate — the suite is forced into `#[cfg(test)] mod` siblings, where the macro is unavailable. **Blocks Tasks 3,4,5,7,8,10,11,12,13,14.** Also unmeasured and important: does `cargo test` even build the `gv-sandbox` binary?
4. **The Network tier cannot reach the network.** `handled_access_net` declares TCP handled with zero net rules added $\Rightarrow$ all TCP denied in both tiers. `git push/fetch/clone` are impossible in the tier that exists solely for them. Ships silently because the test uses a filesystem remote.
5. **`/proc` and `/dev` grants** — fixed in built code via `default_system_trees`; propagate into the plan's Tasks 3/6/7/9 text.
6. **Missing deps:** `probe.rs` (production) calls `tempfile::tempdir()` but `tempfile` is dev-only; `repo_paths.rs` derives `thiserror::Error` but `thiserror` isn't a dependency at all. Both hard compile errors.
7. **`shim_path()` breaks under cargo test** — `current_exe()` is `target/debug/deps/<testbin>`, sibling lookup misses.

NOTABLE (9) — the three vacuous tests are the dangerous ones

Vacuous tests report **green** while proving nothing: - `open_fds()` does `v.retain(|fd| *fd <= 2)` then asserts all `fds ≤ 2` — a tautology. - C2 register-width test casts through

`libc::c_int` (32-bit), truncating `0x1_0000_0000` in userspace before the syscall — and is asserted in the Strict tier where all `socket()` is denied anyway. Doubly vacuous. - INV-10's hostile test expects `OutsideManagedRoot` but bootstrap policy grants no `/tmp`, so `rev-parse` fails first and returns `NotARepository`. Test and code contradict.

Plus: INV-3 sub-cases (a)/(b) untested with a factually wrong justification; the `argv_boundary` red window starts at **Task 3** not Task 6; Task 16.5's `hook_policy_for` has two identical match arms (breaks shipped test `security.rs:835` AND trips `clippy::match_same_arms` under `-D warnings`); `degraded_probe` is called but defined nowhere; `resolve_and_validate` adds a second sync sandboxed git spawn on the interactive read path (blocks a tokio worker, ~doubles the measured 9.9ms); the `gh-credential-helper` tension (`~/.config/gh` is in the exclude list, so HTTPS push can't authenticate).

From `/code-review` on the **ALREADY-BUILT Task 1/2 code (7 more)**

- **sandbox/deps.rs:45 — HIGH, the F10 gate is a no-op.** Off-by-one in cell indexing: the leading `|` yields an empty first element, so `cells[2]` is version not reason. A row with empty "Reviewed alternative" and "Review date" passes. Should be `cells[3]/[4]/[5]` and `cells.len() >= 8`.
- **sandbox/mod.rs:27 — SECURITY.** `BWRAP_BIN = "bwrap"` is a bare name resolved via inherited `PATH` at spawn time while everything else is absolute. Anything that can influence `PATH` substitutes the whole sandbox launcher and the strict tier **silently becomes unsandboxed**. Resolve to an absolute path once at startup and pin it.
- `mod.rs:260` — `probe_argv → shim_argv` hits `unreachable!()` for `Tier::Unsandboxed`; probing a trusted repo panics the server thread.
- `mod.rs:208` — `sandbox_argv` returns bare `["git"]` for `Unsandboxed`, silently dropping `HookMode::Blocked`, so on an ABI-floor-failing host a trusted repo's hooks **run**.
- `mod.rs:106` — `/dev` is granted RW in both tiers and Landlock grants are recursive, so the network tier gets the **host's** `/dev/shm` — contradicting C4 and the doc comment three lines above.
- `deps.rs:26` + `.github/workflows/ci.yml:324` — both halves of the gate miss the idiomatic `libc.workspace = true` shorthand.
- `ci.yml:324` — crate list duplicated with `KERNEL_API_CRATES`, no cross-check.
- Also noted: `Policy::secret_excludes` documented "Absolute paths" while `DEFAULT_SECRET_EXCLUDES` is "Relative to `$HOME`" with **no conversion helper** — a policy site passing the constant verbatim silently re-exposes `~/.ssh`.

What to do first (recommended order)

1. **Measure the replacement Landlock mechanism** (enumerate-and-skip) before writing any Task 3 code. Prove: `~/.gitconfig` readable, `~/.ssh` denied, `~/.config/git/ignore` readable (this was F-NEW-2, it broke `git commit`), `~/.config/gh` denied, rule-count within the kernel's limit, and **a real git commit with no repo-local user.email succeeds** (9 of Tom's 24 repos are like that).

2. **Measure the binary-path mechanism** — build a throwaway crate mirroring the real layout and test `build.rs / current_exe() -walking-out-of-deps/ / CARGO_MANIFEST_DIR`. Answer whether `cargo test` builds the sibling binary at all.
 3. **Measure Landlock net** — do `LANDLOCK_RULE_NET_PORT` rules for 443/80 permit `connect()` while denying others? Test against a local listener, not the internet.
 4. **Then** revise the plan with the measurements, then re-verify, then execute Task 3.
 5. Fix the 7 `/code-review` findings on the built code — the `deps.rs:45` off-by-one and the `BWRAP_BIN PATH` issue are the two that matter most.
-

Lane coordination — how this was being run

Lane A (you) — thomas2025 / Max account, main checkout, orchestrator. Merges PRs, writes plans/ADRs, drives the milestone.

Lane B — "baby" / Pro account (thomas2010), worktree `/home/tom/projects/Git-Vista-pro`. Self-loops via `/loop`, self-serves from `.claude/parallel/task-queue.md`, writes results to `.claude/parallel/pro-result.md`, archives to `.claude/parallel/archive/`. Coordination state lives in `.claude/parallel/state.json` (gitignored). **Currently IDLE — queue is genuinely exhausted.** Nothing in it is servable without #65/#66 unblocking or the diff-spec-endpoint decision. To give it work, write `.claude/parallel/pro-task.md` with a YAML frontmatter header (`task_id`, `issue`, `branch`, `allowed_paths`, `forbidden_paths`, `pr_body_must_contain`) plus a prose body explaining why each boundary exists — the prose is what keeps a worker inside its fence, not the fields. **Bar it from all git writes** (a background checkpointer owns the index) and say why.

Lane C — Codex. Tom is **low on Codex tokens** — use sparingly or not at all. It has a held-back #66 security audit brief at `.claude/parallel/codex-task.md` (C2), still valid but written before there was code to audit. It also built a SQLite doc catalog for the separate `printpdf-mcp` repo (PR #3 there, `codex/docs-catalog`) — **tests never run, no venv, pytest/pydantic not installed.**

Lane D — Grok. Chat-only, no tool or file access — but Tom **can paste real files into it**, and he has offered to. This is the highest-value unused lane right now: an adversarial code review from a model that cannot see our reasoning is exactly what caught the `io_uring` bypass in round 4. Give it whole files plus a sharp question, and keep it **blind** to our conclusions. It has one outstanding unanswered brief at `.claude/parallel/grok-task-g2.md` (overlay dock resolution, 5 questions; Tom pasted an answer to Q3 only — whether Q1/Q2/Q4/Q5 were ever answered is **unknown**, asked twice).

Budget and model policy (as of 2026-07-29 00:16)

Session 3% used · **All models 0% used** (resets Wed 12:00 AM) · **Fable 0% used, its own separate bucket** · 0 credits.

Use Fable (claude-fable-5) for heavy thinking — kernel-semantics reasoning, adversarial verification, design analysis. It draws from a **separate pool** that is completely unused, so it is effectively free reasoning capacity. **Use Opus for code edits.** This is Tom's explicit preference.

Standing rule regardless: right-size every subagent — set `model` AND `effort` per task, never inherit. Mechanical work → haiku/sonnet at low effort. Only the must-not-be-wrong verify stages get the big model at high effort.

Hard rules (violating these has cost real work)

- **One checkpoint, and it is the SOLE git writer.** Check `pgrep -af autocheckpoint` first and kill any predecessor — two racing on the index corrupt each other. Continue the auto-checkpoint N series from `git log` (last was **112**). Subagents are barred from ALL git writes; say why in their prompt ("a background checkpoint owns the index") — an agent given a reason stops and reports instead of crossing the line.
 - **Every merge is a true merge, never squash. Never delete a branch, ever.**
 - Commits: author `claude_2010`, email `262510778+tom2025b@users.noreply.github.com`.
 - Never restart the running server — it steals port 8080 from Tom's live iPad session.
 - Before a doc-only stretch, **say so** so Tom can drop to a cheaper model.
 - Render PDFs, don't print them unless asked.
-

Signed: thomas2025 · 2026-07-29T00:20:00-04:00